

Block 11b: malformed Solana transaction refusal before schema consent

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Immediate target: fork audit/715-11a-test-board-bootstrap-20260928 at fa02818bc4b722d81ba9c977ff06bfc12b2083cf (PR #879), stacked on CI prerequisite PR #880 and accepted Block 10. Code generation predecessor: 7eceaffffa0d305091c46f13e432d9282615370c; review repair: 63296f21288ba8c21f27578a7829c3a346d42c6a; predecessor merge: 85627b3d38335fc72090b9bc06af3d9dc8be9b54. Final containing head and hosted CI belong in the PR body. Main-worktree master template SHA256 at intake: b3ec05e8aeb6db1dfce462116fc8f2bcb57bb7577f627f226665fb0e89b79355.

1. Scope and source reconciliation

The adjacent four-path diff adds an immediate `SOL_TX_REVIEW_MALFORMED` refusal in `fsm_msgSolanaSignTx`, adds all-prefix schema truncation assertions to native tests, advances the companion Python pin to 05c77c948d61c2a6a23aaf961ad7c45037ac739b (companion PR #122), and aligns the CI report's Python PR link. The CI event-authority regression test is inherited from 11p and is outside this adjacent diff. The product handler, runtime schema parser and inherited consent rules were traced at the pinned source. No other product path or dependency pin changes in this unit. Direct and nested submodules are initialized and clean.

Finding S11-01 was reproduced on the historical source base db7c711a6c824c42e7096d4867429bbe94cb6fffb: partial parser output could populate instructions despite a malformed transaction; a matching runtime schema then entered confirmation before the later fallback malformed check. The first guard now classifies the raw transaction immediately after checking that it is present and nonempty. It sends `SyntaxError` and restores the home screen before derivation-path consent, key derivation, signer checks or schema consent. No derived key exists on this failure path. The later fallback remains. Truncation assertions cover every prefix of canonical v1 and v2 schema payloads; the companion Python pin carries wire regressions for malformed legacy trailing bytes and truncated v0 lookup sections, with and without schema, plus valid-signing controls. The current companion regression additionally tries a valid non-standard path for each malformed payload, with and without schema, and requires zero confirmation screens.

Direct pins match the predecessor except `deps/python-keepkey: code-signing-keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec`; `deps/crypto/trezor-firmware 8a392f70a5d5575ece3dfb35f115d4a4b27f497c`; `deps/device-protocol 5fec9e6906a340be5eb3d795ec746769065b2db8`; `deps/googletest 7888184f28509dba839e3683409443e0b5bb8948`; `deps/python-keepkey 05c77c948d61c2a6a23aaf961ad7c45037ac739b`; `deps/qrenc/QR-Code-generator 6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8`; `deps/sca-hardening/SecAESSTM32 71d356a1141624994cf613bd2d2583892e8e6d5a`.

2. Finding and security closure

The sensitive state is the raw transaction and derived signing node, with runtime schema metadata supplied by the host. The observer is the device user at a Solana confirmation screen and the host receiving a signature/failure. The full product build dispatches this handler; Bitcoin-only excludes Solana by product configuration. The allowed output for malformed trailing/truncated transaction encodings is `SyntaxError` before any schema confirmation and no signature. Equivalent malformed representations include legacy trailing bytes and truncated v0 lookup sections, each with a matching or absent schema. A valid matching-schema transaction remains signable after normal consent. The node must be wiped on the early failure path.

Historical emulator wire XML in the cumulative Block 11 archive shows three schema-bearing malformed subcases failing on the old source: they reached confirmation and returned `ActionCancelled` when the test declined. The corresponding fixed historical XML has zero failures, including valid controls. That baseline is a behavior-distinguishing negative control on an earlier source identity, not exact-head proof for this split. After the review repair, the full firmware suite passed 669/669 tests. The Python suite passed 811 tests with 84 declared capability skips (895 total); its screenshot selection included 218 cases (194 passed and 24 capability skips), and all 16 stack contract tests passed with three declared skips. The expanded malformed-path regression passed and requires `SyntaxError` with zero screens across standard/non-standard paths and schema-present/absent cases. Exact results and raw JUnit/log identities are bound in the refreshed archive. Bitcoin-only exact-head coverage is a hosted gate and excludes Solana by product configuration; the report-authority suite inherited from 11p passed 18/18.

The deterministic nine-member 715-11b-controls-20260928.tgz archive has SHA256 6837fea8bf346ad4bbe548963c4373306a8ed2edf6da3fc729f0811fa1f55b63. It binds eight raw JUnit/XML/log files and a manifest with source and companion pins, the declared CI capability mask, case totals, and hashes. Historical malformed

wire baseline/fix XML are retained as controls. The four adjacent source/pin paths are byte-identical between the native-build code head and the merge-prepared head. Every archive member hash verifies; archive tamper checks are rerun after freeze. The historical wire receipt is also documented in 715-11-malformed-schema.md on cumulative PR #877.

3. Local and external checkpoint

The valid Copilot finding is addressed by moving malformed parsing before the non-standard-path warning and key derivation. The local full native suite passes; the companion integration suite verifies malformed requests return `SyntaxError` with no screens across standard/non-standard paths and schema-present/absent cases. Post-edit preflight, exact-head hosted CI, artifact verification and the second Copilot review are recorded in the PR body after report freeze. One of three fresh review rounds has been used. Physical device consent, actual power interruption, release merge and publication are separate gates.

4. Complete adjacent Git inventory

Inventory base: fa02818bc4b722d81ba9c977ff06bfc12b2083cf. Code predecessor: 7eceaffffa0d305091c46f13e432d9282615370c; prerequisite merge: 85627b3d38335fc72090b9bc06af3d9dc8be9b54; first containing report predecessor: 1598ff14581c8e210974ba0401828e547315a6c8. The table was regenerated after that first report commit grew to include its own final rows. Reproduce from the immutable immediate base to the final head recorded in the PR body with `git diff --numstat fa02818bc4b722d81ba9c977ff06bfc12b2083cf..FINAL_PR_HEAD`. Binary counts use Git's dash.

Added	Deleted	Path
1	1	.github/workflows/ci.yml
1	1	deps/python-keepkey
-	-	docs/release/audit-units/715-11b-controls-20260928.tgz
37	0	docs/release/audit-units/715-11b-solana-runtime-20260928.md
-	-	docs/release/audit-units/715-11b-solana-runtime-20260928.pdf
15	5	lib/firmware/fsm_msg_solana.h
7	0	unittests/firmware/solana.cpp